

CONSTRUCTION OS

PRD_8

Corporate Group, Access Control and Data Governance Amendments

Additive and Corrective Product Requirements Document

Version 1.0

3 August 2026

Prepared for Senior Full-Stack Development, Security, DevOps, QA and Product Teams

Document Status and Compatibility

Authority rule

PRD_8 extends and, where explicitly stated, amends PRD_1 through PRD_7. Earlier requirements remain valid unless this document marks them as Superseded, Corrected, Restricted or Deferred. When an implementation conflict exists, the amendment register in Section 2 is authoritative.

Field	Value
Document	Construction OS - PRD_8 - Corporate Group, Access Control and Data Governance Amendments
Status	Developer handoff / confirmed product decisions
Primary purpose	Consolidate post-PRD_7 decisions and remove ambiguity before further implementation
Primary audience	Full-stack developers, architects, security engineers, DevOps, QA, product managers and data-governance reviewers
Dependency	Must be implemented together with PRD_1 through PRD_7
Priority	High: permissions, tenant hierarchy, sensitive data, deletion, document rules and corporate-group data movement
Current platform scope	Central Construction OS platform only; company-owned domains and enterprise SSO are deferred

Contents

- Executive purpose
- Amendment and supersession register
- Global authorization model
- Contract access and collaboration
- Red Flag governance
- Company Owner and Company Admin authority
- Corporate Group data model
- Group permissions and company context
- Child-company removal and data transfer
- Joint Venture privacy
- Finance visibility and expense control
- HR privacy and employee offboarding
- Procurement visibility and selection
- Sales client-change governance
- Projects, Tasks and deadlines
- Minutes of Meeting and contractor collaboration
- Contractor access and performance
- Project-document governance
- Offline conflict resolution
- Client and external-user scope
- Platform scope deferrals
- Data entities and permission services
- Suggested API requirements
- Audit and security requirements
- Migration and backward compatibility
- Test scenarios
- Acceptance criteria
- Open decisions

1. Executive Purpose

PRD_8 formalizes the access-control, corporate-group, data-governance and cross-module decisions made after PRD_7. Its objective is to prevent developers from implementing contradictory rules across contracts, Finance, HR, projects, documents, corporate groups, Joint Ventures and Platform Administration.

Core design principle

A user sees only what their role, company context, department membership, direct assignment or explicit grant allows. Access to one record never implies access to unrelated sensitive records. Corporate-group convenience must not merge legal-entity data or erase historical ownership.

2. Amendment and Supersession Register

The following register is mandatory for implementation and regression testing.

Area	Earlier direction	PRD_8 decision	Effect
Client Portal	PRD_1 described a configurable client portal.	Clients do not have direct Construction OS access in the current scope. Client requests are entered by authorized internal users.	Client Portal is removed from the active roadmap and must not be exposed in the UI.
Company domains and SSO	Later discussions considered company subdomains, own domains and Microsoft/Google SSO.	Current implementation remains inside the central Construction OS platform only.	Custom domains, white label and enterprise SSO are deferred.
Company Admin authority	Earlier documents limited some Company Admin access.	Company Admin has full operational control across all company modules and sensitive records, except Company Owner controls.	Expand Company Admin permissions; preserve audit and Owner protection.
Company Owner protection	One later answer incorrectly allowed Admin reset/deactivation.	Company Admin cannot edit, reset, deactivate, remove, impersonate or modify Company Owner.	This correction supersedes any conflicting text.
Owner recovery	Recovery authority was undecided.	One Platform Admin may recover Owner credentials after strict identity verification, without company-data access.	Add isolated credential-recovery workflow.
Company deletion	Earlier deletion process lacked final detail.	Seven-day read-only standby, followed by manual Platform Admin approval before any deletion.	No automatic deletion; Platform Admin either approves or returns request to Owner for cancellation.
General project documents	PRD_1 emphasized formal review before official publication.	Uploader may mark a project document official immediately; uploader or superior may delete it to a 30-day recycle bin.	Amends general project-file behavior; module-specific controlled records remain separately governed.
Contract documents	Earlier contract control was broad.	Official contract files/revisions may be uploaded or replaced only by Contract Owner, Legal Manager or Company Admin.	Contract-specific rule overrides general document rule.
Project Manager Finance access	Earlier dashboard language could expose broader project finance.	PM sees only approval statuses and contractor payment status; overdue contractor payments include overdue days only.	Restrict PM financial fields and APIs.
Completed projects	PRD_1 emphasized read-only archive.	Any Department Manager involved in the project may reopen it; no reason required, but audit is mandatory.	Add controlled reopening exception.
Minutes of Meeting	Earlier MoM was primarily a separate record/workflow.	MoM is published on each related Task. Involved contractors may comment.	Task becomes the operational collaboration surface while MoM remains linked evidence.
Corporate Groups	PRD_1 supported parent/subsidiary at a high level.	PRD_8 defines shared staff, separate legal data, inherited permissions, Parent Owner authority and child-	Major extension; implement dedicated group context.

Area	Earlier direction	PRD_8 decision	Effect
		company removal.	
Offline conflicts	Earlier PRD selected full offline mode.	Conflicting offline edits preserve both versions until authorized review/merge.	Compatible clarification; automatic overwrite is forbidden.
Restricted access duration	Earlier rules allowed temporary grants in some places.	Manual grants to restricted records are permanent until explicitly revoked.	Apply to the access engine unless a future record-specific rule states otherwise.

2.1 Meaning of amendment labels

- **Superseded:** The earlier rule must no longer be implemented for the affected scope.
- **Corrected:** A later clarification fixes an inaccurate or unsafe earlier statement.
- **Restricted:** The earlier feature remains, but access, fields or actors are narrower.
- **Extended:** The earlier feature remains and PRD_8 adds required behavior.
- **Deferred:** The feature is not part of the current implementation phase and must remain hidden or disabled.

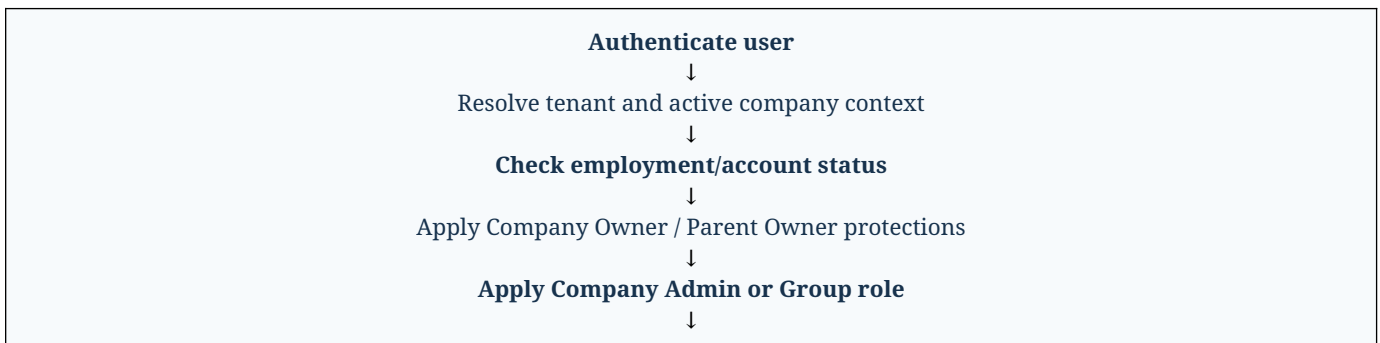
3. Global Authorization Model

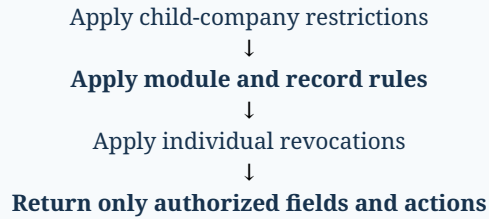
Construction OS must use deny-by-default authorization at tenant, company, module, record and action levels. Frontend visibility is not security; every API and file request must be checked by the backend.

3.1 Access sources

Access source	Description	Default duration
Company role	Permission granted through an active role inside the selected company context.	While role and employment remain active
Department membership	Permission inherited because a department is granted access to a record.	While department remains linked, unless individually preserved or revoked
Individual involvement	Reviewer, approver, contributor or watcher assignment.	Permanent read-only access while employed, unless explicitly revoked
Manual grant	Specific user or department added by an authorized person.	Permanent until explicitly revoked
Corporate Group role	Group-level default inherited across child companies.	While group role remains active; child restrictions may apply
External assignment	Contractor access to their own assigned records.	Limited to assigned scope and company relationship

3.2 Evaluation order





3.3 Core rules

- Sensitive records are hidden by default unless the user has an explicit access path.
- Access to a contract does not grant access to linked invoices, payment schedules, bank data, salaries, internal Legal notes or unrelated Finance reports.
- When an employee leaves the company, all company access is revoked regardless of previous involvement.
- When an internal employee changes department but remains employed, previously earned record access remains unless explicitly revoked.
- A revocation by Department Manager, Contract Owner or Company Admin overrides department membership and individual assignment for the affected record.
- Manual restricted-record access remains permanent until explicitly revoked.
- Every permission grant, removal, restoration and inherited-access change must be auditable.

4. Contract Access and Collaboration

4.1 Internal user access

An internal user becomes involved in a contract when added as a reviewer, approver, contributor or watcher. Involvement grants full visibility of the contract record but does not grant editing rights to the official contract.

Capability	Internal involved user	Contract Owner / Legal Manager / Company Admin
View full contract and all revisions	Allowed	Allowed
View contract attachments, approvals and comments	Allowed	Allowed
Download and print	Allowed	Allowed
Comment and reply	Allowed	Allowed
Raise red flag	Allowed	Allowed
Upload comment attachment	Allowed; remains comment attachment	Allowed
Upload or replace official contract document	Not allowed	Allowed
Modify official contract metadata	Not allowed	Allowed
Formal approve/reject contract	Not allowed unless actor is one of the authorized roles	Allowed
View linked Finance/HR/internal Legal records	Not implied by contract access	Separate module permission required

4.2 Department access

- When a department is granted contract access, every active member and future new member receives read-only access.
- The Department Manager may revoke access for specific employees without providing a reason.
- The Contract Owner and Company Admin may also revoke or restore access.
- Revocation is logged with actor, affected user, contract ID, date and time.

- If a department is removed from the contract, department-derived access ends. Users individually assigned to the contract keep access.
- An employee removed from an individual contract role keeps read-only access while still employed, unless explicitly revoked.

4.3 Authorized grant actors

Contract Owner, Legal Manager, Project Manager, relevant Department Manager and Company Admin may grant a user or department access to one specific contract. Access does not automatically extend to other contracts in the same project or involving the same contractor.

4.4 External contractor access

Rule	Requirement
Scope	External contractors see only their own assigned contracts and documents.
Allowed actions	View, download, comment, upload requested files and raise red flags.
Comment visibility	Contractor, Contract Owner, responsible department, Legal where involved and Project Manager for the linked project.
Project Manager visibility	PM sees contractor comments, uploads, red flags and full response history for their project.
Restriction	External contractor access never expands to unrelated internal records, other contractors, company Finance, HR or Legal notes.

4.5 Formal contract approval

- Only Contract Owner, Legal Manager or Company Admin may formally approve or reject a contract.
- Any one authorized person may approve or reject; a fixed multi-step sequence is not required by default.
- A rejection blocks normal approval until revised/resubmitted or overridden by a superior in the company hierarchy.
- A superior override requires no mandatory reason but must be audited.
- After an override, the contract returns to Under Review. The same superior who authorized the override provides final approval.

5. Red Flag Governance

Red Flags are a universal risk-warning mechanism available to users who already have access to a contract or document. They do not edit or annotate the file itself.

5.1 Location and presentation

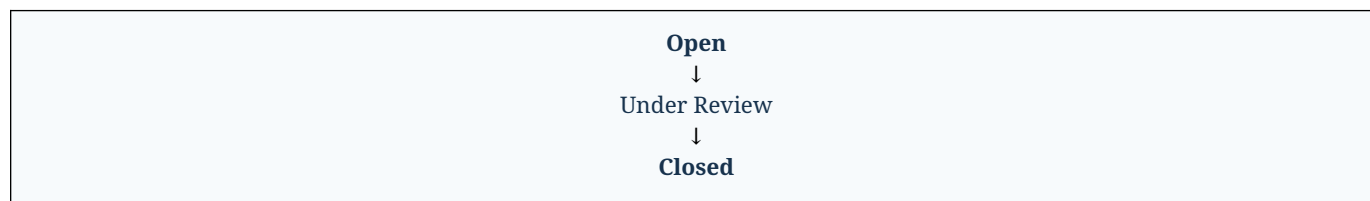
- Red Flags appear in a dedicated Red Flag panel beside the comment area, not inside the document and not as a normal comment.
- The default panel shows Open and Under Review flags only.
- Closed flags are removed from the panel and remain only in the immutable audit log.
- Critical flags remain pinned as a persistent banner for every user who can access the record until closure.

5.2 Severity and notifications

Severity	Default recipients	Behavior
Low	Record/contract owner	Visible alert; no workflow pause
Medium	Owner + responsible Department Manager	Visible alert; no workflow pause

Severity	Default recipients	Behavior
Critical	Owner + responsible Department Manager + Legal + Project Director	Pinned banner and immediate alert; CEO receives no automatic alert but can see all flags

5.3 Lifecycle



Action	Who may perform it	Rule
Create	Any user with record access	Mandatory explanation; attachment/evidence optional
Move to Under Review	Contract Owner, responsible Department Manager, Legal, Project Manager or Company Admin	No automatic change when a follow-up task is created
Close	Same authorized resolver group	No mandatory resolution comment; closure metadata is logged
Change severity	Raiser or authorized resolver	No mandatory reason; change is audited
Delete while Open	Original raiser only	Allowed only if nobody has responded; deletion leaves no remaining record
Reopen after closure	Nobody	Closed flag cannot reopen; create a new flag

5.4 Follow-up tasks

- The person raising a flag may optionally create a follow-up Task.
- The Red Flag panel displays linked Task ID, assignee, due date and live status.
- Creating or completing the Task does not automatically change or close the Red Flag.
- Authorized resolvers must change the flag status manually.

6. Company Owner and Company Admin Authority

6.1 Company Owner

Highest company authority

The Company Owner is above all Company Admins. Company Admins cannot edit, reset, deactivate, remove, impersonate, transfer, or otherwise modify the Owner account or ownership status.

- Only the Company Owner may transfer ownership or request permanent company deletion.
- Only the Company Owner may create, remove or change another Company Admin.
- The Company Owner account can never be impersonated by a Company Admin.
- If the Owner loses access, one Platform Admin may recover credentials after strict identity verification.
- Owner recovery does not grant the Platform Admin access to projects, Finance, HR, Legal, documents or other company data.

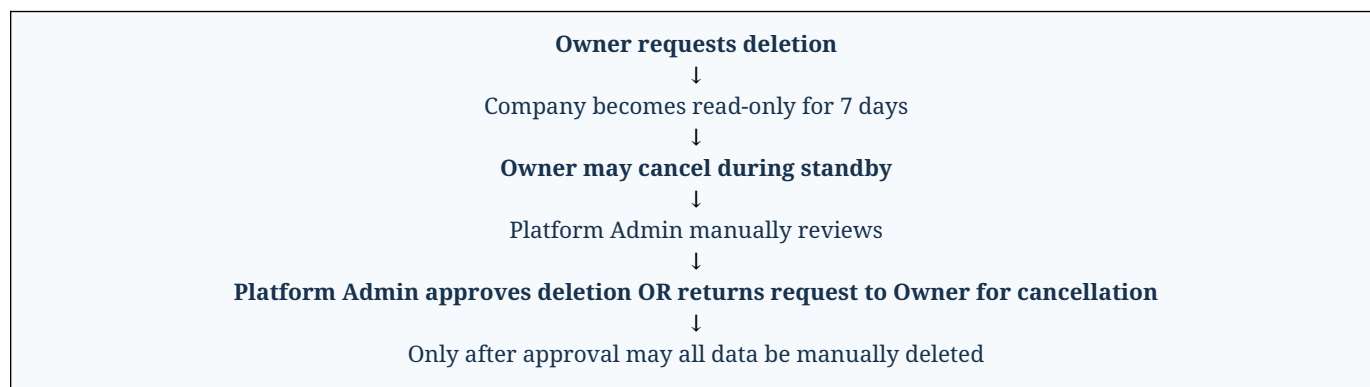
6.2 Company Admin

Capability	Company Admin
View all company modules and sensitive records	Allowed
Create, edit, approve, delete and restore records across modules	Allowed
Manage users, roles, permissions and company settings	Allowed
Impersonate employee accounts	Allowed without employee approval; full audit attribution required
Impersonate Company Owner	Forbidden
Create/remove/modify another Company Admin	Forbidden; Owner only
Transfer ownership or delete company	Forbidden; Owner only
Archive audit logs	Allowed
Alter or permanently delete audit logs	Forbidden

6.3 Impersonation

Even though the Company Admin receives full access while impersonating an employee, every action must remain attributable to the Admin session. The system must never make the audit trail appear as if the employee independently performed those actions.

6.4 Company deletion



- Deletion does not run automatically at the end of the seven-day period.
- During standby, all users may view but cannot create, edit, approve, delete or otherwise modify records.
- Platform Admin cannot independently reject or indefinitely pause the request.
- No production data, file, database or backup may be permanently deleted without explicit Platform Admin approval.

7. Corporate Group Data Model

A Corporate Group contains one Parent Company and one or more Child Companies. The model must support shared staff and consolidated dashboards while preserving each company as a separate legal and data entity.

Object	Rule
Parent Company	Top-level company and ownership authority for the group
Child Company	Separate legal entity with independent records; no separate Company Owner
Parent Company Owner	Only Owner in the group; full operational authority across Parent

Object	Rule
	and all children
Group Admin	May create or remove child companies and operate group administration as allowed
Child Company Admin	Manages daily operations within the child company; subordinate to Parent Owner
Group-level employee	One account and role operates across every child company automatically
Group-level department	Shared staff and consolidated view; underlying records remain company-specific

7.1 Legal-entity separation

- Projects, contracts, Finance, HR, Legal, procurement, warehouse, sales, documents, permissions and audit history remain separate for each child company.
- Consolidated dashboards aggregate authorized data but do not rewrite source ownership or merge record IDs.
- Every record stores the legal company that created and owns it.
- Cross-company searches and reports must display the source company clearly.

8. Group Permissions and Company Context

8.1 Group employees

- A Group-level employee assigned at the Parent level automatically receives access to every child company.
- The same user account is reused; duplicate accounts or invitations are forbidden.
- Group-wide default permissions apply to all child companies.
- Each Child Company Owner/Admin role is represented by Child Company Admin because child companies do not have separate Owners.
- A Child Company Admin may restrict specific modules, records or actions for a Group-level employee inside that child company.
- The Parent Company Owner is never limited by child-company restrictions.

8.2 Parent Company Owner

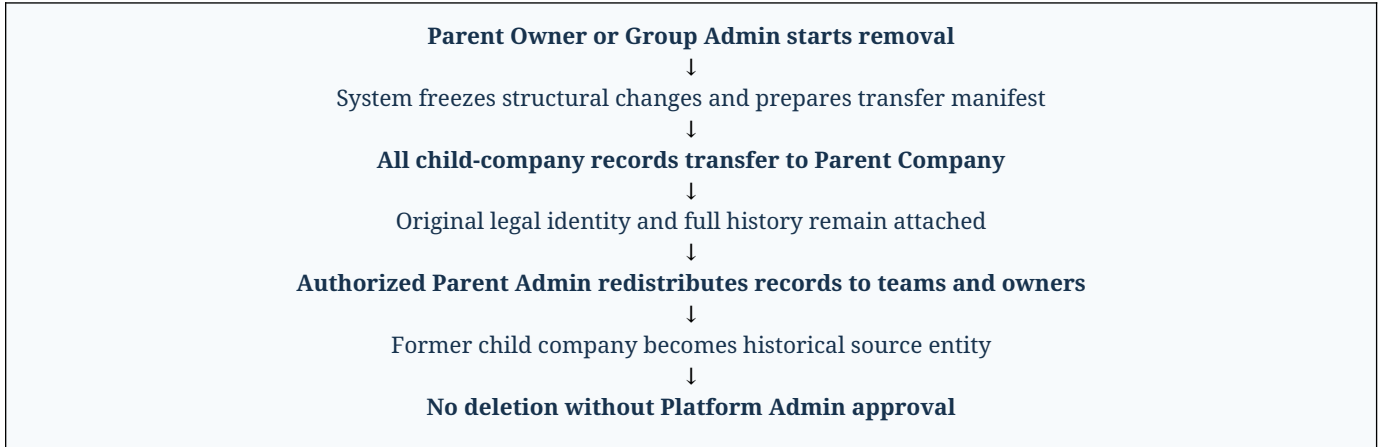
Authority	Requirement
Visibility	Automatic full access to every child company and every module
Operations	View, create, edit, approve, delete, restore and manage permissions
Sensitive data	Includes Finance, HR, Legal, contracts, salaries and audit records
Restriction handling	Child-company restrictions do not limit Parent Owner
Ownership	Child companies do not have an equal or separate Owner

8.3 Child Company Admin

Child Company Admins may manage the child company, restrict Group users, and operate records according to Company Admin rules, but they cannot override or modify the Parent Company Owner.

9. Child-Company Removal and Data Transfer

Removing a child company from the group is not the same as deleting its data. The operation must transfer all records to the Parent Company and preserve complete lineage.



9.1 Transfer scope

The transfer includes all Projects, Tasks, HR, Procurement, Warehouse, Sales, Contracts, Finance, Legal, documents, comments, approvals, notifications, audits and other operational records.

9.2 Lineage preservation

- Original child-company name and company ID remain on every record.
- Original creators, participants, departments, approvers, timestamps, revisions and ownership history remain unchanged.
- The system must not make transferred records appear as if they were originally created by the Parent Company.
- All cross-record links, file references, audit events and permanent IDs must survive transfer.
- Parent Company distribution creates new responsibility assignments without rewriting historical responsibility.

9.3 Deletion boundary

No implicit deletion

Child-company removal may transfer and deactivate the source entity, but it may not permanently delete any record, file, database or backup. Permanent deletion requires the separate Platform Admin-approved company-deletion workflow.

10. Joint Venture Privacy

Joint Venture projects remain deny-by-default across partner companies.

- Each partner sees only records explicitly marked as shared with the Joint Venture.
- Private company records remain invisible even when linked to the same JV project.
- Shared status must be stored at record level and audited.
- Access to one shared record does not expose its private linked records.
- JV partner users must remain inside their own company context while viewing shared records.

11. Finance Visibility and Expense Control

11.1 Project Manager visibility

Finance information	PM access
Company cash flow	No
Company profit and loss	No
Bank details	No
Employee salaries	No
Broad Finance reports	No
Spending request result	Approval/rejection status only
Contractor payment	Status only: Pending, Approved, Partially Paid, Paid or Overdue
Overdue contractor payment	Status + number of overdue days
Invoice amount, paid amount, balance, retention or deductions	No, unless separately authorized

11.2 Expense submissions

- Any employee may submit a company expense or bill.
- Every submission goes directly to Finance for review; no amount threshold is used.
- Supporting proof is mandatory: invoice, receipt, document or photo.
- The backend must reject submission when no proof is attached.
- Finance may approve, reject or request information according to its module permissions.

12. HR Privacy and Employee Offboarding

12.1 Sensitive HR data

Information	Authorized viewers
Salary	HR, Company Admin and Company Owner
Disciplinary records	HR, Company Admin and Company Owner
Private HR documents	HR, Company Admin and Company Owner
Attendance	HR and direct superior; other permissions as configured
Lateness	HR and direct superior
Leave status	HR and direct superior
Work schedule	HR and direct superior
Certifications, training and performance records	Not automatically available to direct superior

12.2 Employee departure

- All company access is revoked when the employee leaves.
- All open Tasks automatically transfer to the employee's Department Manager for reassignment.
- Unfinished drafts and company-related files automatically transfer to the Department Manager.
- If the Department Manager is inactive or absent, HR or Company Admin manually selects a replacement manager.
- Historical authorship and action records remain attributed to the former employee.

13. Procurement Visibility and Supplier Selection

Requirement	Decision
Quotation-price visibility	Procurement, Finance, relevant Project Manager and Company Admin
Final supplier selection	Joint approval by Procurement Manager and relevant Project Manager
Finance role in supplier choice	No automatic supplier-selection approval; Finance approval may still apply to a separate financial transaction
Audit	Quotation access, evaluation and final selection must be recorded

14. Sales Client-Change Governance

Sales cannot officially promise a client a design or construction change until all required internal reviews are complete.



- If a department rejects the request, Sales may revise and resubmit it.
- An authorized superior may override a rejection.
- Original rejection, revisions, resubmissions and overrides remain in the audit history.
- Clients do not access the platform; Sales or another authorized internal user records communications.

15. Projects, Tasks and Deadlines

15.1 Reopening completed projects

- Any Department Manager who was involved in a completed project may reopen it.
- No mandatory reason or explanation is required.
- The reopening actor, timestamp, former status and new status must be recorded in the audit log.
- Reopening restores operational editing only according to the user's normal permissions.

15.2 Deadline-change notifications

When a project deadline changes, automatic notifications go only to users assigned to Tasks directly affected by that change. The platform must calculate affected Tasks and avoid notifying unrelated project members.

15.3 Task and record access after departure

Transferred Tasks, drafts and files must preserve their original creator and history while assigning a new current responsible manager.

16. Minutes of Meeting and Contractor Collaboration

- Minutes of Meeting are published on every Task they concern.
- The MoM remains a linked record and timeline event; publication on a Task does not duplicate or detach the source record.
- An external contractor involved in the Task may view and comment on its MoM.
- When the contractor comments, notify Task Manager, Project Manager, meeting organizer and all internal users assigned to the Task.
- Contractor comments remain subject to the contractor visibility rules in Section 4.4.

17. Contractor Access and Performance

17.1 Contractor performance evaluations

Any internal user who was involved with a contractor may submit a performance evaluation after work completion. Each evaluation must identify the reviewer and link to the contractor, project, Task and work scope. Visibility and aggregation rules remain configurable until separately decided.

17.2 No Client Portal

Contractor portal functions remain permitted for assigned work. Client platform access is not permitted in the current scope and must not be confused with contractor access.

18. Project-Document Governance

18.1 General project files

- An authorized uploader may mark a project document as official immediately.
- The uploader and authorized superiors may delete the document.
- Deletion moves the file to a recycle bin for 30 days, after which it is permanently deleted.
- Recycle-bin restore permissions follow Company Admin and applicable superior rights.
- Creation, official marking, deletion and restoration must remain auditable while the record exists.

18.2 Controlled-status clarification

Implementation clarification

“Official project document” means the file is an official record in the project library. It does not automatically mean Approved, Signed, Issued for Construction, Posted, Legally Executed or Financially Posted. Module-specific controlled statuses and actors still apply.

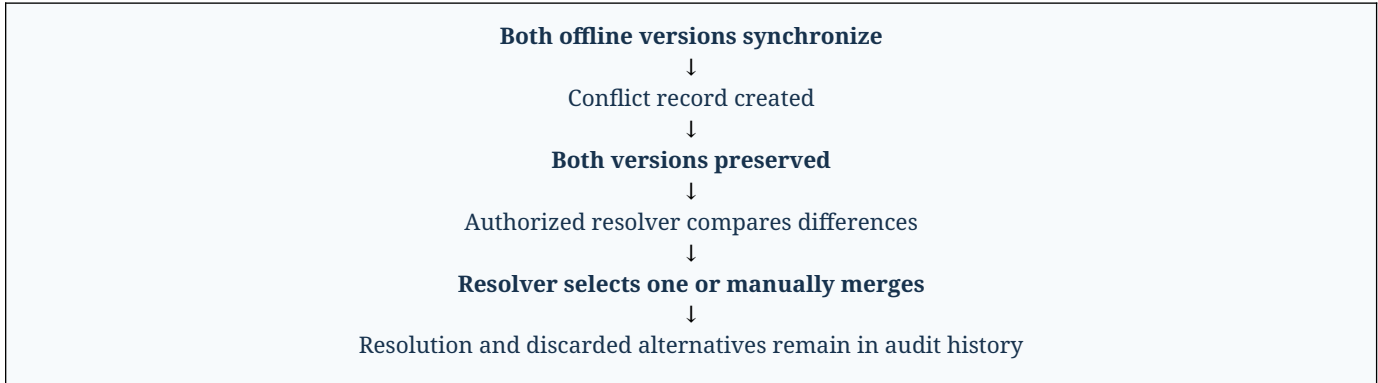
18.3 Module-specific exceptions

Record type	Official-file rule
Contract official files/revisions	Only Contract Owner, Legal Manager or Company Admin may upload or replace
Contract comment attachments	Remain comment attachments; never automatically become official contract documents
Finance evidence	Submission requires proof; Finance workflow controls approval/posting
HR private files	Visibility remains limited to HR, Company Admin and Company Owner

Record type	Official-file rule
Drawings and engineering records	Project-library official status may be immediate, but approval/revision/issue status remains governed by the drawing workflow
Minutes of Meeting	Official linked record published to relevant Tasks according to Section 16

19. Offline Conflict Resolution

When two offline edits conflict, the platform must never silently overwrite one user's work.



Authorized resolvers: record owner, Task Manager, relevant Department Manager or Company Admin.

20. Client and External-User Scope

User type	Current access model
Client	No direct Construction OS account or Client Portal access
Independent professional applicant	Public-profile onboarding and Platform Admin approval under PRD_6
External contractor	Limited portal/access to own assigned contracts, Tasks, MoM, uploads and related records
Internal employee	Company workspace according to role, department, record grants and restrictions
Group employee	One account across Parent and all child companies with inherited permissions and child restrictions

21. Platform Scope Deferrals

The following capabilities must not delay or complicate the current platform implementation:

- Company-owned login domains such as os.company.com.
- Custom company subdomains as the primary login architecture.
- Microsoft Entra, Google Workspace, Okta or SAML Single Sign-On.
- Full white-label removal of Construction OS branding.
- Company-domain email authentication as an access prerequisite.

These may be defined later as a separate Enterprise PRD. Current users authenticate and operate inside the central Construction OS platform.

22. Data Entities and Permission Services

22.1 New or extended entities

Entity	Purpose
CorporateGroup	Parent company, group identity and group configuration
GroupMembership	Group-level user assignment, role and status
GroupDepartment	Shared department definition and consolidated dashboard context
CompanyPermissionOverride	Child-company restriction or exception for a Group user
RecordAccessGrant	User/department grant, source, actor, scope and permanence
RecordAccessRevocation	Revocation actor, affected subject, record and timestamp
ContractParticipant	Reviewer, approver, contributor or watcher assignment
RedFlag	Severity, status, explanation, raiser and record link
RedFlagTaskLink	Optional follow-up Task and live status reference
CompanyTransferManifest	Complete child-to-parent record transfer manifest
TransferredRecordLineage	Original company and immutable source metadata
OfflineConflict	Two or more versions awaiting resolution
OfflineConflictResolution	Resolver, selected/merged result and audit data
CompanyDeletionRequest	Owner request, standby, Platform Admin decision and execution record
OwnerRecoveryCase	Strict identity verification and credential-only recovery evidence

22.2 Authorization service requirements

- Central policy evaluation service used by APIs, files, search, notifications and UI navigation.
- Ability to explain why a user has access: role, department, individual involvement, group role, manual grant or external assignment.
- Ability to calculate effective access after child-company restrictions and individual revocations.
- Field-level response filtering for Finance, HR, Legal and contractor data.
- Batch-safe authorization for lists and search without leaking restricted titles or metadata beyond existing PRD rules.
- Cache invalidation immediately after role change, revocation, employment termination or company transfer.

23. Suggested API Requirements

Endpoint group	Examples
Access	POST /records/:id/access; DELETE /records/:id/access/:subjectId; POST /records/:id/access/:subjectId/restore
Contracts	POST /contracts/:id/participants; POST /contracts/:id/official-files; POST /contracts/:id/approve; POST /contracts/:id/reject
Red Flags	POST /records/:id/red-flags; PATCH /red-flags/:id/status; PATCH /red-flags/:id/severity; POST /red-flags/:id/tasks
Corporate Group	POST /groups; POST /groups/:id/children; POST /groups/:id/members; PATCH /companies/:id/group-restrictions
Child transfer	POST /groups/:id/children/:companyId/remove; GET /transfers/:id/manifest; POST /transfers/:id/complete

Endpoint group	Examples
Finance filtering	GET /projects/:id/contractor-payment-status; POST /expenses with mandatory evidence
Offboarding	POST /employees/:id/offboard; POST /offboarding/:id/assign-replacement-manager
Offline conflicts	GET /conflicts; POST /conflicts/:id/resolve; POST /conflicts/:id/merge
Owner recovery	POST /platform/owner-recovery; POST /platform/owner-recovery/:id/complete
Deletion	POST /companies/:id/deletion-request; POST /platform/deletion/:id/approve; POST /platform/deletion/:id/return-to-owner

24. Audit and Security Requirements

- Audit records are immutable. Company Admin may archive them but cannot alter or permanently delete them.
- Every sensitive read, grant, revocation, restoration, impersonation, override, transfer and deletion action must identify the acting account and effective context.
- Company Admin impersonation must record Admin identity, impersonated employee, session start/end and every action.
- Owner recovery logs must never include company business content.
- Child-company transfers must be transactional, resumable and verified by record counts and file checksums.
- No record may lose its permanent ID or original company lineage during transfer.
- External contractor APIs must enforce company and assignment scopes independently of the frontend.
- Red Flag alerts and task links must not reveal records to users who lack access.
- All file downloads require authorization at request time, including comment attachments and recycle-bin restoration.

25. Migration and Backward Compatibility

25.1 Existing permissions

- Migrate contract participants into explicit ContractParticipant records.
- Compute permanent read-only grants for currently employed participants where historical involvement is known.
- Do not grant access to linked Finance, HR or internal Legal records during migration.
- Convert department contract access into department grants and individual revocation support.
- Flag ambiguous legacy access for Company Admin review rather than broadening permissions automatically.

25.2 Existing companies and groups

- Create CorporateGroup only for companies explicitly configured as parent/child.
- Preserve every current tenant and company ID.
- Do not merge child-company data merely because a Group dashboard is enabled.
- Generate source-company tags and lineage fields before any child-removal transfer becomes available.

25.3 Existing documents

Existing approved, signed, posted or issued files retain their controlled status. The new immediate official-project-file option must not downgrade or overwrite previous approval/revision metadata.

26. Critical Test Scenarios

Scenario	Expected result
Contract isolation	Architect with contract access can read/comment/flag the contract but

Scenario	Expected result
	cannot see linked invoices or edit official files.
Department grant	New employee joining an authorized department receives the contract; a manager revocation blocks access immediately.
Persistent involvement	Removed contributor remains read-only while employed; departure revokes all access.
External contractor	Contractor sees only assigned documents and cannot discover other contractors or internal records.
Red Flag	Critical flag sends correct recipients, pins banner and remains visible until manually closed.
Admin vs Owner	Company Admin can control company data but cannot modify or impersonate Owner.
Owner recovery	Platform Admin resets Owner credentials without opening tenant business data.
Company deletion	Seven-day read-only standby occurs; no deletion happens until manual Platform Admin approval.
Group inheritance	Group employee accesses every child by default; child restriction blocks a module; Parent Owner remains unrestricted.
Child removal	All records transfer to Parent with IDs, authorship and original company identity intact.
JV privacy	Partner cannot see a record until explicitly shared with JV.
PM Finance	PM sees contractor payment status and overdue days only, never amount.
Expense proof	Expense submission without receipt/photo/document is rejected.
HR privacy	Direct superior sees attendance/leave/schedule but not salary or disciplinary files.
Offboarding	Open Tasks and drafts transfer to manager; all user access is revoked.
Sales change	Sales cannot confirm client change before technical, Finance and Legal approvals.
Document deletion	Uploader deletes official project file; it remains recoverable for 30 days.
Offline conflict	Two offline versions survive; authorized resolver merges and audit records the decision.

27. Acceptance Criteria

1. The system has one centralized authorization service enforcing deny-by-default rules on backend APIs and file access.
2. Contract access provides read-only collaboration and does not expose linked sensitive modules.
3. Department grants, future-member inheritance, individual revocation and restoration work as defined.
4. Official contract files can be changed only by Contract Owner, Legal Manager or Company Admin.
5. Red Flags support Low, Medium and Critical severity, correct notifications, Open/Under Review/Closed status and optional task links.
6. Company Admin has full company operational control but cannot modify or impersonate Company Owner.
7. Owner recovery is Platform Admin-only, identity-verified and credential-only.
8. Company deletion remains read-only for seven days and never executes without manual Platform Admin approval.
9. Corporate Group supports one Parent Owner, Group Admins, child Admins, shared employees and separate legal records.
10. Group users automatically access every child, with child restrictions and Parent Owner override behavior.
11. Child-company removal transfers all records to Parent and preserves complete lineage and history.
12. No child-company data is deleted through removal.
13. JV partner access is limited to records explicitly shared with the JV.

14. PM financial visibility is restricted to approved fields and contractor-payment status.
15. Every expense submission includes mandatory proof and routes directly to Finance.
16. HR sensitive information and direct-supervisor views match Section 12.
17. Offboarding transfers Tasks/files and revokes all access.
18. Procurement quotation visibility and joint supplier approval match Section 13.
19. Sales client changes require technical, Finance and Legal approval before confirmation.
20. Completed projects can be reopened by involved Department Managers and the action is audited.
21. MoM is published to related Tasks and contractor comments trigger the required notifications.
22. General project documents support immediate official status and 30-day recycle-bin deletion while controlled module statuses remain intact.
23. Offline conflicts preserve all versions and require an authorized resolution.
24. Client Portal and company-domain/SSO features are not exposed in the current release.
25. Automated tests cover tenant isolation, company context, group inheritance, revocation, field filtering and data transfer.

28. Open Decisions

The following topics remain intentionally undecided and must not be guessed by developers:

- Who may mark records as shared with a Joint Venture.
- Visibility model for individual contractor performance evaluations versus aggregated scores.
- Exact assignee-selection workflow after child-company records transfer to Parent.
- Large data-export permissions by Department Managers versus Company Admin/Owner only.
- Whether general project-file recycle-bin deletion should retain minimal tombstone audit after permanent file deletion.
- Whether Platform Admin must provide the Owner a final export before company deletion.
- Enterprise custom domains, white-labeling and SSO implementation.
- Any future Client Portal or external client access model.

Developer rule

Open decisions must be implemented behind configuration flags or left out of the current release. They must not be resolved through undocumented assumptions.

Final Implementation Statement

PRD_8 is the authoritative amendment layer for the decisions it covers. The development team must map each requirement to existing PRD_1-PRD_7 components, identify affected database migrations and APIs, and provide a regression plan before implementation. No permission broadening, cross-company merge, record deletion or external-user access may be introduced beyond the explicit rules in this document.